

SCC-4179 | Restrict CPNI Field Access

Great Plains sandboxes | Read-only least-privilege readiness assessment

Environments	GreatPlainsMerge 00DEa00000GkAsHMAV GreatPlainsUAT 00DEa00000FZILBMA1
Review date	26 August 2026
Evidence	SOQL read-back FieldPermissions and PermissionSetAssignment
Decision	Changes Requested - not ready for promotion
Boundary	No records, assignments, metadata, deployment, activation, or Production changes

ARCHITECT DECISION

Do not promote yet. The approved CPNI permission set is correct, but profile and broad permission-set grants still expose both fields, so permission-set-only access is not achieved.

Acceptance outcome

#	Scope	Result	Evidence
1	Named profiles	Fail	System Administrator, API Only, and Standard User still grant read and/or edit in both sandboxes.
2	Other profiles	Fail	UAT also exposes both fields through Product, GPC-BI & Reporting, and GPC-Residential CRC Team.
3	Non-target permission sets	Fail	Account and Contact - Full Access and Heroku and Data Hub Permissions retain read access.
4	Approved permission set	Pass	Contact Encrypted CPNI Read/Write Access grants read/edit to both fields in Merge and UAT.
5	Production and runtime proof	Not run	Production was not inventoried and no named-user UI/API UAT or deployment was performed.

Solution and control path

The solution is declarative FLS: remove both CPNI fields from every profile and non-approved permission set, retain read/edit only in the approved permission set, then prove exclusivity with named users and permission read-back.

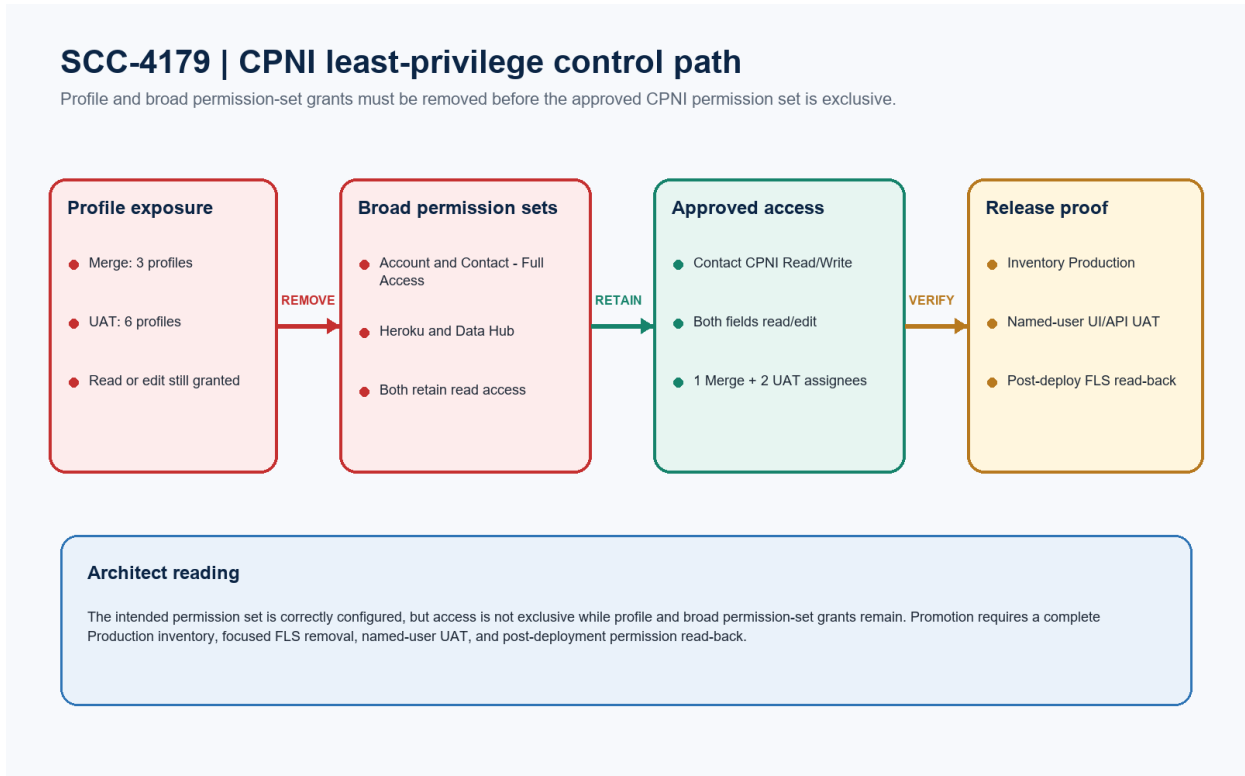


Figure 1. SCC-4179 CPNI least-privilege control path

DESIGN READING

Green is the intended grant. Red access paths must be removed. Amber is the release evidence gate before promotion.

Current CPNI access evidence

GreatPlainsMerge

Access path	CPNI Password	CPNI Pin	Acceptance
System Administrator	Read	Read / Edit	Fail
System Administrator - API Only	Read / Edit	Read / Edit	Fail
Standard User	Read	Read	Fail
Account and Contact - Full Access	Read	Read	Fail
Heroku and Data Hub Permissions	Read	Read	Fail
Contact Encrypted CPNI Read/Write Access	Read / Edit	Read / Edit	Pass - 1 assignment

GreatPlainsUAT

Access path	CPNI Password	CPNI Pin	Acceptance
System Administrator + API Only	Read / Edit	Read / Edit	Fail - 2 profiles
Standard, Product, GPC-BI, GPC-Residential	Read	Read	Fail - 4 profiles
Account and Contact - Full Access	Read	Read	Fail - grant path
Heroku and Data Hub Permissions	Read	Read	Fail - 1 assignment
Contact Encrypted CPNI Read/Write Access	Read / Edit	Read / Edit	Pass - 2 assignments

EXCLUSIVITY BLOCKER

The target permission set works, but it is not the only grant path. Every profile and non-target permission set must lose both read and edit before SCC-4179 can pass.

Implementation and release boundary

Component type	Focused scope	Required action
Contact fields	CPNI_Pin__c; CPNI_Password__c	Reference only - no schema change
Named profiles	System Administrator; API Only; Standard User	Remove read and edit for both fields
Additional UAT profiles	Product; GPC-BI & Reporting; GPC-Residential CRC Team	Remove read access; inventory Production equivalents
Broad permission sets	Account_and_Contact_Full_Access; Heroku_and_Data_Hub_Permissions	Remove both field grants
Approved permission set	Contact_CPNI_Read_Write_Access	Preserve read=true and edit=true
Code and automation	Apex, Flow, validation rules, layouts	No change

Release sequence

Phase	Required evidence
Pre-deployment	Retrieve Production FLS; inventory all grant paths and target-set assignees; assess integrations; run focused check-only validation; obtain Security and release approval.
Deployment	Promote only approved FLS removals to UAT first; retain the target permission set; deploy to Production only after named-user UAT and an approved change window.
Post-deployment	Read back FieldPermissions and assignments; run negative and positive UI/API tests; review Setup Audit Trail; capture job ID, scope, results, and sign-offs.
Rollback	Restore the approved metadata backup only if a critical dependency fails; remove any temporary emergency permission assignment after resolution.

PRODUCTION GATE

Do not use the sandbox component list as a complete Production package. Production was not inspected; its full FLS and assignment inventory is mandatory before validation or deployment.

UAT and approval gates

Test	Pass evidence
Negative UI	Named users without the target set cannot see either field on View or Edit.
Negative API	The same users cannot query or update either field through the approved API test path.
Positive access	A named user with only the target set can view and edit both fields using synthetic UAT data.
Exclusivity	FieldPermissions read-back shows the target permission set as the only remaining read/edit grant path.
Regression	Approved integration and reporting owners confirm expected behavior after profile and broad-set removal.

Required approval gates

#	Required action	Owner	Evidence needed
1	Inventory Production	Salesforce Admin / Security	Complete profile, permission-set, assignment, integration, and reporting impact inventory.
2	Approve authorized users	Data Owner / Security	Final target-permission-set assignee list and emergency-access process.
3	Validate focused package	Release Manager	Check-only job ID, exact components, test result, and explicit deployment approval.
4	Run named-user UAT	QA / Business Owner	UI/API negative and positive tests with record IDs, timestamps, and screenshots.
5	Promote and read back	DevOps / Salesforce Admin	Deployment receipt, FLS/assignment read-back, audit trail, and sign-offs.

Ready-to-paste architect response

STORY COMMENT

Architect review completed for SCC-4179 in GreatPlainsMerge and GreatPlainsUAT. Changes Requested: Contact_CPNI_Read_Write_Access correctly grants read/edit to CPNI Pin and CPNI Password, but permission-set-only access is not achieved. Merge still grants access through three profiles and two broad permission sets; UAT grants access through six profiles and two broad permission-set definitions. Production was not inspected. Complete the Production inventory, remove both field grants from every profile and non-target permission set, retain the approved permission set, run focused check-only validation and named-user UI/API UAT, then capture post-deployment FLS and assignment read-back. No records, assignments, metadata, activation, deployment, or Production changes were made during this review.